



Security Policies: 5.1

What rules are you following to provide CIA?

- Confidentiality, integrity & Availability

High level Strategies

Detailed Security goals

- WiFi-Usage

- Security Policies ensure the "What & Why"

Information Security Policies:

The big list of all security related Policy

Compliance requirements

"What happens when..."

List of roles & responsibilities

Just words & letters

Acceptable Use Policies (AUP):

What are users permitted to do

Covers many topics

Used by organization to limit legal liability

Business Continuity:

Not everything goes to plan

Alternatives in the event of failure

- Manual transaction, paper receipts

Must be tested prior

Disaster Recovery Plan:

Business continuity plan that affects e-commerce

- Technology / IT

- Human disasters

- Natural Disasters

Recovery location

Data Recovery Plan

Employee Availability

Security Incidents:

Handling user prompted attacks

DDoS

- Botnet attack

Confidential information is stolen

Incident Response Roles:

Incident response team

IT Security Management

Compliance Officers

Technical Staff

User Community

NIST SP800-61

Computer Security Incident Guide

The incident response lifecycle

Prep, Detection, Analysis, Containment, Eradication, Recovery, LL

Software Development Lifecycle (SDLC):

Systems development life cycle

• App dev life cycle

Many ways to get from idea to app

No 'best way'

• Helps to have a framework

AGILE: Faster, Consistent Processes

WATERFALL: Linear

Change Management:

How to Make a Change

- Upgrade Software, Firewall Configs

One of the most common risks in the enterprise

Often overlooked or ignored

Have Clear Policies

Sometimes extremely difficult to implement

Security Standards: 5.1

A formal definition for using Security technologies + Processes

May be written in house

May be Preexisting

ISO / NIST Standards

Passwords:

What makes a good Password?

Define acceptable authentication model

- No local accounts, only LDAP to the AD database

Create Policies for Password rules.

Other Password policies

Access control:

How does an organization Control data Access

- No discretionary / Mandatory only etc.

Determine how a user gets Access

Determine how Access may be removed

Physical Security:

Granting Physical Access

- Doors, locking Areas, Perimeter Security
- Different for Contractors, employees, visitors

Define Particular Procedures

- Controlling / Offboarding Policies

Encryption:

Define Specific for encrypting & storing data

Password storage

- Methods and techniques

Data encryption minimums

- Algorithms for data in use, transit or at rest

Will be different at each stage

Security Procedures: 5.1

Change Management:

Formal Process for Managing Change

- Avoid downtime, Confusion & Mistakes

Nothing Changes Without the Process

- Determine the Scope of the Change
- Create a Plan
- Get end-user approval
- Present the process to Change Control team
- Have a back-out plan

Onboarding:

Bringing a New Person in

IT agreements need to be signed

Create accounts

Provide required hardware

Offboarding:

Should be Pre-planned

What happens to the hardware

Account information disabled

- Not always documented

Playbooks:

Conditional Steps to follow in the case of a particular event

Step-by-Step Processes

- Manual Procedures

Often integrate into a SOAR Program

- Security Orchestration, Automation, and response
- Make Security teams more efficient

Monitoring and Revision:

IT Control is constantly changing

Update Security Policy

- Tighten Change control

Change to an individual Process

New Security Controls

- Protect against emerging threats

Governance Structure:

Boards: Panel of stakeholders

Committees: Subject matter experts

- Considers inter dependencies
- Determines next step

Governance Structures:

Government Entities

- Legal entities

Centralized / Decentralized

- Made by one or many people.

Security Considerations: 5.1

Regulatory:

Regulations are often mandated

- Security Principles are usually a foundational consideration

- Logging, data storage, data protection, and retention

Sarbanes-Oxley Act (SOX)

- The Public Company Accounting Reform & Investor Protection

HIPAA: keeps health information secret

Legal:

The security team is often tasked with legal responsibilities

Holding data relevant for legal proceedings

Security breach notifications

A legal requirement in many jurisdictions

Cloud computing can make make this challenge:

- Data moves between jurisdictions without human intervention

- The security team must follow legal guidelines

Industry:

The industry may require specific security considerations

Electrical Power & Public Utilities

Medical: Highly Secure

Geographical Security:

Local / Regional

National

- Federal Government / National Defense

- Multi-State Organizations

- State Sources

Global

- Legal Concerns May Vary

Data Roles & Responsibilities: 5.1

Data Owner:

- VP of Sales, Treasurer
- Primary Respon
- Oversees all aspects

Data Roles:

Data Controller: Manages the Purposes & Means by Which Personal Data is Processed

Data Processor: Processes data on behalf of data Controller, often third party

Portfolio Controller & Processor

- Portfolio Determiner (Controller)
- Portfolio Controller (Data Processor)

Data Custodian: Responsible for data accuracy, Privacy, Security

Manages Access rights and logs

Risk Management: 5.2

Growth Yields Risk

- Manage Potential Risk
- Quantify inside/outside threats

Performing a Risk Assessment:

One time Assessment

- Company acquisition

Continuous Assessment

(Change Control, Common Chng.)

Ad Hoc Assessment

Assessment for one particular Purpose

- Focus on one thing/object

A committee is created + risk assessment proceeds

Unlikely to have subsequent

Recurring Assessment:

The evaluation occurs on scheduled intervals

An internal assessment, no need for a third party

A mandated risk assessment

- Keep's track costs on file

Risk Analysis: 5.2

Qualitative Risk Assessment:

Identify significant risk factors

- Ask opinions about the significance
- Display Visually with traffic grid or similar method

Risk Factor	Impact	Rate of occurrence	Cost of Controls	Overall
Legacy Apps				
Unknowns Storfe				
No anti virus				

Quantitative Risk Assessment

ARO (Annualized Rate of Occurrence)

Asset Value (AV)

• The asset value of an asset to an organization

• Exposure Factor (EF)

• Percentage lost due to disaster

Quantitative Risk Assessment:

SLE (Single Loss Expectancy)

Asset Value (AV) $\times$ Exposure Factor (EF)

• $1000 \times 1.0 = 1,000$ (SLE)

Annual Loss expectancy: $ARO(7) \times 1000 = ALE = 7,000$

Impact:

Life: Most important consideration

Property: Risk to buildings and assets

Safety

Firmness

Likelihood and Probability:

Qualitative (Likelihood): Low, medium, high

Quantitative (Probability): Statistical measure

Risk Appetite + Tolerance:

The amount of acceptable risk before measurement is taken

Risk Appetite: Resilience

Risk Tolerance: An acceptable variance from risk variance (logics)

Risk Appetite: A highway speed limit, acceptable limit

Risk Tolerance: May go over speed limit and not get fined

- Tolerance produces on many factors

Risk Register:

Each risk is documents

- Solutions/ options Review
- Monitor Results

What are the key risks that could impact the company

Risk owners

Risk threshold: Cost of mitigation $\geq$ Money Saved by mitigating

Risk Management Strategies: 5.2

Transfer:

- Move the risk to another Party
- Buy Cybersecurity insurance

Accept:

- 'We'll take the risk'

Accept with an exception

Regulation cannot be relaxed

May need approval

Accept with exception

- Monitor security updates must be applied in 3 days

Avoid: Abstain from Participating in High Risk clients

Mitigate: Decrease risk level

- Invest in security systems

Risk Register:

Formal document identifying all tangible risks

Commonly includes critical & tangible risks

Business Impact Analysis: 4.2

Recovery:

Recovery time objective (RTO)

- Time to get up and running

Recovery Point objective (RPO)

- Bring back online, how much loss is acceptable

Mean Time To Repair (MTTR)

- Important metric for determining cost

Mean time between Failures (MTBF)

- Time between outages
- Statistical Plan for possible outages
- Total Uptime / Total Downtime

Third-Party Risk Assessment: 5.3

All Organizations Work with Vendors

Important company data is often shared

Perform risk assessment of third party

Use contracts for clear understanding

Penetration Testing:

Simulate an attack

Often a compliance uptake

• You and third party

Penetration may be third party

Rules of Engagement:

Scope or Privacy

• On-site Physical breach, internal test, external test

• Network hacking, have access only...

The rules

• IP ranges

• Emergency contacts

• Handling sensitive data

Right-to-audit clauses:

Common to do work with outsiders

Third party matters: Are they secure

Right to audit should be in contract

- Have the ability to audit third party

Evidence of internal audits

Evaluate effectiveness of security controls

May be realized for compliance

Often coming out by third outside company

- Access Management, Off-boarding

- Personnel Reliability often

Supply-Chain-Analysis:

The system involves when creating a product

Get a Product or Service from vendor to customer

Evaluate coordination between groups

Document business process changes

Security Controls Verify

Independent Assessment:

Bring in Smart Person or team to evaluate Security and Performance

Specialists in their field

New Perspective

Vendor Selection:

Due Diligence: Checking/Vetting a company before buying

- Investigate & verify information

Conflict of interest:

- A Personal Interest could compromise judgement

- Third-Party employees the brother of CEO

- Doing business with competitor

Vendor Monitoring:

Ongoing management of Vendor relationship

Reviews should occur on a regular basis

- Financial Health Check, News coverage

Assign a Person in Charge Vendor relationship

Questionnaire:

Get answers directly from vendor

Security Related questions

- The divorce process

- Plans for disaster recovery

Results Updated frequently

Assignment Types: 5.3

Common Agreements

Service Level Agreement (SLA)

- Minimum terms for service provided

Contract with ISP

- No more than 4-hour service downtime...

Common Agreements:

Memorandum of Understanding (MOU)

Broad overview of how two organizations will conduct business

Memorandum of Agreement (MOA)

- One step above MOU
- May not be concrete
- Legally agree to objectives

Master Service Agreement (MSA)

- Legal contract and agreement of terms
- Future projects will be based on this

Work Order (WO) / Statement of Work (SOW)

- Specification of items to be completed
- Used in conjunction with a MSA
- Scope, location, references

Non-Disclosure Agreement (NDA)

Confidentiality agreement between two parties

Protects Confidential Information

Unilateral or bilateral (or multilateral)

Formal contract with signatures

Common Agreement:

Business Partners Agreement (BPA)

- Joining business

Decision Making

Peoples for Companies or Museum

Compliance: 5.4:

Meeting the Standards for laws, Policies, and regulations

Healthy Catalog of Rules

Penalties: Fines, Loss of employment, incarceration

Scope

Compliance Reporting:

Internal

- Managed by CCO (Chief Compliance Officer)

External

- Documentation reviewed by external or industry regulators
- Missing or ongoing review

Regulatory Compliance:

Sarbanes-Oxley Act (SOX)

Health Insurance Portability and Accountability Act (HIPAA)

GLBA

HIPAA non-Compliance Fine + Sentences:

- Fine up to \$ok, 1 year jail tie
- False Pretenses look, 5 yr
- Intent to sell 250k, 10 yrs

Civil Fine: Maximum of 25k

Reputational Look:

Getting hacked isn't a great look

- Often results in disclosure

Uber got hacked, announced a year later

- Paid 148 million in fines

Uber's former Chief Cyber Security

Other Consequences:

Loss of license

- Economic Sanctions
- Organization cannot sell products

Contractual Implies

- Contract broken if one breaches conditions
- Must be remedied

Compliance Monitoring:

Ensure Compliance in day-to-day activities

Due Diligence / Due care

- Act honestly & Good faith

Attestation and Attestation

- Separate matter sign off

Internal and External tools

- Monitor with tools
- May require ongoing monitoring

Automation

- Must have
- Collect data from People & Systems
- Combine data & process

Privacy: 5.4

Privacy legal implications

- A constantly evolving set of guidelines

- Local / regional

National

- Privacy for everyone, HIPAA

Global

GDPR - General Data Protection Regulation

EU

- Data Protection and Privacy

- Name, Address, Phone, email, address

People have more power

Gives 'data subject' rights to be forgotten

Data Subject:

Any information relating to an identified or identifiable natural person

Everybody, everywhere

Privacy is data from perspective of data subject

Data Responsibilities:

Data Owner: VP, Treasurer

Data Controller: Managing how its used

Data Processor: Using the information

Data Custodian:

Data inventory & retention:

Listing of all collected data

• Owner, Features, Format

Internal Use: Product Collaboration, IT Security, data Quality checks

External Use: Doing to Share Research

Audits and Assessments: 5.5

Not just for taxes

Cybersecurity Audit:

• Examines interacting software, data

• Checks for vulnerabilities

• Can be internal or third party

Attestation: Opinion of third party on result

Internal Audits:

Compliance

Audit Committee: Group responsible for risk management

Self Assessments: Have organizations perform their own checks

External Audits:

Controlled out by third party

Examinations:

• Require hands on research

Assessors: How they are doing

Penetration Testing: 5.5

Physical Penetration Tests

CS can be circumvented by physical means

- Malware test testing
- Attends to know as by any means

Penetration Perspectives:

Offensive: Red Team

- Attack system

Defensive: Blue Team

- Defense team

Integrate both teams together

Working Knowledge:

Known environment: Full disclosure

Partially known environment: MIT

Unknown environment: "Blind test"

Reconnaissance:

Need information prior to an attack

Understand Security Policy

Minimize the attack area

Build a network map

Passive Reconnaissance:

Learning as much as possible from open sources

Social Media, Online Forum

Social Engineering

Dumpster Diving

Active Reconnaissance:

Trying the doors

Relatively easy to be seen

Ping scans, Port scans

OS scans, OS fingerprinting

Security Awareness: 5.6

Phishing Campaigns:

Testing Your own employees

- Third Party / Or internally

Automated Process

Failures need additional testing

Recognize a Phishing Attack

- Spelling, grammar error
- Domain name
- Unusual attachments
- Requests for Personal info

Email filtering working as needed?

New Click link, or file attachment

Should have reporting processes

Anomalous Behavior Recognition:

Risky behavior

- Modifying host files
- Refusing OS Patches

Different country login

Increase in data transfers

Note Unintentional data / Misconfig

Reporting and Monitoring:

Track and analyze Security awareness metrics

- Automate
- Pushy click rates

Initial + Rolling

Development:

Create Security Awareness team

- Determine role for training, monitoring, Policy Creation etc

Establish minimum awareness metrics

Involvement of management

Execution

Creating the training material

Document success measurement

Identify the stakeholders

Deploy the training material

User Training: 5.6

Security Awareness Training

Standardized Training

Also applies to third parties

Detailed documentation & records

User Guidance & Training:

Policy / Handbooks

Situational Awareness

- Email links (phishing)

- Unsecured URLs

- USB drives (third parties)

Barriers for information

Insider Threats

- Difficult to spot signs

- Fake monitors

- Multi-Layer approach

Password Management

(length, complexity, etc)

Connectors using technology (best practice)

User Guidance & Training:

Reputable media & culture

Social Engineering

- Train users extensively against phishing

- Users on farm line or device

Operational Security

- Understanding of farm characters & persons

Hybrid / Remote Work:

- Family / Friend Access

- Additional Security at endpoints